대외비 2급

침해사고 대응 지침서

2012. 02

연세대학교 의료원
YONSEI UNIVERSITY HEALTH SYSTEM

제 개정 이력

제 개정번호	일자	제 개정 내용 요약	작성자
2012-01	2012-02-22	ISO27001 인증 대비 전면 개정	조남인
2016-01	2016-09-26	위원회 명칭 변경 (정보보호 위원회)	조남인
2016-02	2017-01-16	[별지 제1호 서식] 침해사고 보고서 내용 추가	조남인
2023-01	2024-01-08	제6조(정보시스템 침해사고 발견) 제10조(정보시스템 장애 시 대응 및 복구)	조남인

목 차

제1조 (목적) 3

제2조 (적용범위) 3

제3조 (책임과 역할) 3

제4조 (발생 가능한 침해사고의 유형) 4

제5조 (침해사고의 위험 등급) 5

제6조 (정보시스템 침해사고 발견) 5

제7조 (보안사고 대응 조직 구성) 6

제8조 (침해사고 대응 업무절차) 7

제9조 (사후 관리) 8

제10조 (정보시스템 장애 시 대응 및 복구) 9

제11조 (시행과 갱신) 10

제1조 (목적)

본 지침서는 연세대학교 의료원(이하 산하기관을 포함하여 '의료원'이라 칭함) 침해사고 발생 시에 적절한 대응 절차 및 지침을 설명함으로써 자산을 안전하고 효율적으로 보존 관리하며 침해사고에 적절히 대응함을 목적으로 한다.

제2조 (적용범위)

침해사고가 발생할 수 있는 의료원 내의 모든 정보 자산을 적용범위로 하며, 자산을 이용하거나 정보전달을 행하는 모든 사용자 및 정보시스템을 대상으로 한다.

제3조 (책임과 역할)

① 최고정보보호책임자 : 의료원의 정보시스템 총괄 책임자로서 의료원 정보보호와 개인정보보호 총괄 책임자 역할을 수행하며 침해사고대응을 총괄 관리한다.

② 정보보호책임자 : 최고정보보호책임자에 의해 위임된 정보보호 업무를 수행한다.

③ 정보보호관리자 : 각 부서장으로서 부서의 정보보호와 개인정보보호를 직접 수행하며 부서 보안사고에 대한 책임을 진다.

④ 정보보호실무책임자 : 정보보호 주관 부서장으로서 의료원 정보보호와 개인정보보호 정책 수립 및 이행과 정보보호관리자(각 부서장)의 정보보호 활동을 지원하며, 침해사고 발생 시 침해사고 대응 조직의 팀장역할을 수행한다.

⑤ 정보보호 및 보안 실무담당자 : 정보보호실무책임자가 임명한 정보보호 및 개인정보보호 업무 담당자로서 의료원 정보보호 및 개인정보보호를 위한 관리적/물리적/기술적 부문에서 각 부서의 관련 제반 업무를 지원하며 본 지침서의 이행 점검을 수행한다.

⑥ 부서 정보보호담당자 : 정보보호관리자(각 부서장)가 임명한 부서의 정보보호담당자로서 의료원 정보보호 정책이 이행될 수 있도록 부서 내에서 정보보호 업무를 성실히 수행한다.

⑦ 사용자 : 직번 계정(ID)과 도메인 계정(AD)을 부여 받아 정보시스템에서 제공하는

서비스를 이용하여 업무를 처리하거나 정보를 획득하는 자로서 의료원 교직원 뿐 아니라, 파견업체나 협력업체 등 외부자를 포함하며, 사용자는 의료원의 정보자산을 보호하고, 정보보호 규정 및 지침서를 성실히 준수해야 할 의무를 갖는다.

제4조 (발생 가능한 침해사고의 유형)

침해사고는 내・외부의 악의적인 사용자에 의해서 의료원의 자산에 대한 피해 또는 유출 등이 발생하는 것으로 다음에서 분류된 내용의 사건이 발생할 경우는 침해사고로 규정한다.

① 사고 유형

1. 서비스의 중단

i.의료원의 자산에 물리적인 손상이 발생하여 서비스가 중단되는 경우

ii.서비스 거부공격(DoS), 바이러스 등으로 인한 자산의 일부 또는 전체의 서비스가 중단되는 경우

2. 고객정보 또는 의료원 기밀정보의 유출

i. 정보에 접근 가능한 내・외부자에 의한 대량정보의 유출

ii. 고객정보 또는 의료원 기밀정보를 보유한 정보시스템의 해킹으로 인한 정보의 유출

iii. 중요 장비 또는 주요 정보 저장 매체(디스크, CD, tape, USB 등)의 도난으로 인한 정보의 유출

iv. 협력업체를 통한 정보의 유출

v. 도청, 감청 또는 네트워크 스니핑(sniffing)에 의한 정보의 유출

vi.경쟁 병원 및 의료원 외부로 정보자산("기밀", "대외비")을 고의 또는 무단 유출

3. 진료기록 등의 의료 정보 변조 또는 수정하는 것

i. 정보에 접근 가능한 내・외부자에 의한 의도적 조작의 경우

ii.상기 유출된 기밀을 활용하여 제공 또는 의료 정보 조작 행위 등을 발생시키는 경우

iii. 환자 건강정보, 진료기록 등 의료정보와 의료원 중요정보 등을 보유한 정보시스템에 대한 해킹으로 인한 경우

4. 의료원이 제공하는 서비스나 정보 등을 이용하여 의료원 이미지를 실추시키는 것

i.의료원 홈페이지에 대한 해킹으로 인한 경우

ii.고객 정보 유출 등의 보안사고가 발생하여 언론 등에 보도됨으로써 의료원의 이미지에 크게 부정적인 영향을 준 경우

제5조 (침해사고의 위험 등급)

침해사고가 발생했을 경우에는 위험 등급에 따라서 적절한 대응을 하여야 하며, 위험 등급은 다음과 같다.

① 1호(긴급)

1. “제4조 발생 가능한 침해사고의 유형”에 해당하는 경우로서 의료원의 자산에 피해가 발생하여 정상적인 서비스에 영향을 주거나 의료원의 중요 정보에 대한 유출 또는 변조 등이 발생한 경우이다.

② 2호(주의)

1. 내・외부로부터 지속적인 취약점 수집(scanning 등) 행위가 발견되는 경우
2. 내・외부로부터 지속적인 접근 시도가 발견되는 경우
3. 내・외부로부터 비정상적인 패킷(packet)들의 전송량이 증가하는 경우
4. 확산 속도가 빠른 바이러스가 외부에서 발생한 경우

제6조 (정보시스템 침해사고 발견)

① 정보시스템운영담당자 및 사용자 또는 정보보호 및 보안 실무담당자는 다음 각 호의 상황

발생시 침해사고가 의심되므로 즉시 침해사고 대응절차에 따라 조치를 취해야 한다.

1. 타 기관에서 자신의 컴퓨터가 해킹을 당했거나 경유지로 이용되었음을 통보해온 경우
2. 개인정보의 유출이 발견된 경우
3. 정보시스템 가동 및 서비스가 중단된 경우
4. 서버 및 PC내 저장된 정보가 유출, 파괴, 변조된 경우
5. 사용자들이 컴퓨터의 비정상적인 증상을 보고한 경우
6. 해커들이 자주 사용하는 프로그램이 발견된 경우
7. 장시간 혹은 비정상적인 시간에 수행 중이거나 특이한 명칭의 프로세스가 있는 경우
8. 네트워크 스캔 등의 침입시도 기록이 확인된 경우
9. 비 인가 사용자 또는 부적절한 사용자 기록이 있는 경우
10. 비정상적으로 실패횟수가 많은 로그인 기록이 있는 경우
11. 현업사용자가 관리자 권한으로 정보시스템 접근한 경우

② 운영담당자는 침해사고 발생 상황이라고 판단될 경우에는 정보보호 주관부서에 즉시 통보하여야 한다. 단, 아래의 예와 같이 긴급한 상황에서는 피해를 최소화하기 위해서 네트워크 인터페이스 단절, 전원 off 등의 선 조치를 수행할 수 있다.

1. 분산 서비스 거부공격(DDoS)을 당하고 있어 정상적인 동작이 불가능한 경우
2. 침입자에 의해 서버의 중요 파일이 삭제되고 있는 경우
3. 트로이 목마 등의 악성프로그램이 실행되어 정상적인 접근 제어를 실시하더라도 다른 경로를 통한 침입자의 지속적인 공격 시도가 있는 경우
4. 기타 침입자의 공격에 대한 대응 수단이 없는 경우

3 삭제 <2024.01.08>

제7조 (보안사고 대응 조직 구성)

① 최고정보보호책임자는 보안사고 발생 보고를 받은 즉시 보안사고 등급에 따른 영향 범위

등을 감안하여 정보보호관리자(소속 부서장), 정보보호실무책임자, 정보보호 및 보안 실무담당자, 분야별 IT 운영담당자(서버/네트워크/DB/응용시스템)를 소집하고 보안사고 대응 조직(이하 “대응팀”이라 함)을 구성한다.

② 최고정보보호책임자는 보안사고 등급이 1호인 보안사고는 사고 처리가 종료될 때까지 대응팀을 총괄 관리하며 운영한다. 2호인 보안사고는 정보보호실무책임자가 대응팀 총괄 관리, 운영한다.

③ 대응팀은 기본적으로 정보보호 및 보안 실무담당자와 분야별 정보시스템 운영담당자를 포함하며, 법률적인 대응이나 대외 언론 매체 등에 대한 대응이 가능한 홍보팀, 인사운영팀, 감사팀, 법무팀 인원을 포함하도록 한다.

④ 대응팀장은 보안사고 대응을 위해 관련 조직에 필요 인력의 대응팀 참여나 지원을 요청할 수 있으며, 해당 부서장은 이의 요청에 대해 적극 협조하여야 한다.

⑤ 고객정보와 관련된 침해, 유출 등의 사고이거나 고객정보와의 관련성이 의심되는 경우, 해당 부서 정보보호관리자(또는 부서 정보보호관리자가 지정한 자)가 반드시 대응팀 내에 포함되도록 한다.

⑥ 대응팀장은 보안사고와 관련된 내용을 사고 대응을 위해 필요한 최소 인력에 국한하여 공유하여야 한다.

⑦ 대응팀장은 보안사고 대응을 위한 기술 지원 등이 필요하다고 판단되면 각 산하 병원 및 기관에 지원을 요청하도록 한다.

제8조 (침해사고 대응 업무절차)

① 일반사용자는 업무수행 시 발생되는 정보보호 관련된 모든 문제점과 위반사항에 대하여 정보보호 주관부서에 즉시 보고해야 할 의무를 갖는다. 보고해야 할 위반사항은 “제6조 정보시스템 침해사고 발견”의 각 호에 명시된 바와 같다.

② 각 부서 정보보호담당자는 보안사고 발생시 즉시 피해상황에 따라 네트워크 분리 등의 피해 최소화에 필요한 조치를 취해야 한다.

③ 서버 및 네트워크의 이상작동, 변경유무, 정보유출 등을 확인한다.

④ 모든 정보시스템상의 문제는 발견 즉시 각 부서 정보보호담당자가 정보보호 주관부서에 통보하여야 한다. 침해 상황을 보고할 경우 다음의 사항이 포함되어야 한다.

1. 정보시스템 관련정보 : 서버명, IP주소, OS명칭 및 버전, 주요정보 및 응용시스템
2. 침해사고 개요 : 발생시간, 발견경위, 기타 참고자료

⑤ 정보시스템 운영부서는 침해사고 접수 시 즉시 사고분석을 실시하며, 피해상황, 진원지, 침해사고 유형, 타 정보시스템에 대한 영향을 파악하고, 정보시스템 접속차단 등 대응방안을 마련하여 사고로 인한 영향을 최소화한다.

⑥ 정보시스템 운영부서는 접수 받은 내용을 토대로 "[별지 제3호 서식] 침해사고시 점검항목"을 참조하여 침입흔적 및 침입경로를 조사한다.

⑦ 침해사고가 일어난 정보시스템 및 접속경로를 확인할 수 있는 네트워크 장비의 로그 등을 안전한 백업 매체에 보관하여 증거를 확보한다.

⑧ 침입자의 접속 경로를 추적, 확인한다. 만약 내부 단말기에서 침입한 경우에는 현재의 단말 위치를 확인하여 단말기 책임자와 접속 경위 등을 조사한다. 그리고, 외부 네트워크로부터 침입한 경우에는 네트워크 담당자 및 정보보호시스템운영담당자들과 협조하여 로그를 유지하도록 하고, 접속 경로를 조사한다.

⑨ 정보보호 주관부서에서는 관련 대책을 마련하여 적용하며, 사고발생 및 조치결과에 대하여 최종적으로 보고서를 작성하여 최고정보보호책임자에게 보고한다.

⑩ 의료원에서 해결할 수 없는 사항이 발생되면 정보보호 주관부서는 대외기관(검찰, 경찰, 한국인터넷진흥원, CERT 전문업체 등)에 의뢰하여 지원을 받을 수 있다.

제9조 (사후 관리)

① 정보보호실무책임자는 발생된 정보보호 사고를 유형별로 통계, 분석하여 관리하고, 향후 정보보호 대책에 반영할 수 있도록 하여야 한다.

② 정보보호 주관부서에서는 침해상황에 대한 기록을 유지 관리하며, 동일 사고의

재발방지를 위해 조치절차를 수립하고 교육 및 홍보를 실시한다,

③ 최고정보보호책임자는 정보보호 정책을 재검토하고 필요 시 정보보호위원회를 통해 정책, 통제 등을 변경, 강화하도록 한다.

④ 보안 사고의 원인이 내부자에 의한 문제로 드러날 경우, 인사 규정 등 관련 규정에 의거 징계절차를 수행할 수 있다.

⑤ 정보보호실무책임자는 보안사고 발생 시 즉각적인 대응이 가능하도록 "[별지 제2호 서식]비상연락망"을 항상 최신 상태로 유지, 관리하여야 한다.

1. 업무나 조직 변경 사항 등을 즉각적으로 반영하여야 한다.
2. 최소 분기 1회 현황을 점검한다.
3. 야간이나 휴일에도 연락이 가능하도록 사무실 이외 2가지 이상의 연락처를 유지한다.
4. 외부 지원 조직, 유지보수 업체 등을 포함한다.

제10조(정보시스템 장애 시 대응 및 복구)

① 사용자는 업무 수행 시 발생되는 정보시스템 운영에 관련된 모든 보안 문제점에 대하여 즉시, 관련 부서장 및 정보보호 주관 부서에 보고해야 할 의무를 갖는다.

② 정보시스템 장애 발생 시 피해상황에 따라 최소한의 필요한 조치를 취하며 비상연락망을 통하여 연락을 취해야 한다.

③ 정보시스템 운영부서는 장애에 대한 대응조치를 상황 별로 대처할 수 있는 상황 별 세부지침서에 따라 다음과 같이 조치할 수 있도록 한다.

1. 전체 정보시스템 장애 시에는(서버다운 등) 장애 정도에 따른 대응프로세스 별 대처 및 조치를 하도록 한다.
2. 야간 및 공휴일에 장애 시에는 원인분석 및 장애시간 경과에 따라 해당 대응 프로세스로 신속하게 조치하도록 한다.

④ 정보시스템 장애 복구는 각 서버 및 DB, 네트워크, 응용프로그램의 긴급복구 대책에 따라

신속한 조치를 취해야 한다.

⑤ 정보시스템 장애 복구 및 상황 종료 후 사후 관리대책을 마련하여 향후 상황에 대처할 수 있도록 한다.

⑥ 기타 사항 및 상세 내용은 “장애 유형별 장애 처리 지침”과 “u-Severance 장애대응 지침”을 따른다.

제11조(시행과 갱신)

상기 지침서의 시행과 갱신을 위한 상세한 세부사항은 정보보호규정 ‘제4장 정보보호 정책’에 준한다.

[별지 제1호 서식] 삭제 <2024.01.08>

[별지 제2호 서식] 침해사고 점검 항목

침해사고시 점검항목

침해사고 시에 점검항목 (Windows NT)	점검여부
사용자 계정과 그룹을 점검한다	
비인가된 응용프로그램, 프로세스, 서비스가 실행되고 있는지를 점검한다	
시스템과 네트워크 환경설정을 점검한다. ('ipconfig /all', 'netstat -na')	
비 인가된 파일공유 또는 사용되고 있는 세션을 점검한다	
실행중인 스케줄러를 점검한다	
허가되지 않는 시스템으로부터의 접속 이나 비정상적인 행위에 대한 로그를 점검한다	

침해사고 시에 점검항목 (UNIX)	점검여부
'w', 'who', 'finger' 명령 등을 이용하여 인가된 사용자만이 접속하고 있는지의 여부	
'ps', 'top' 명령 등을 이용하여 process 들의 정상적인 동작여부 및 CPU 사용량 점검	
'netstat' 명령을 통하여 비 인가된 접속 및 의심스러운 port의 open 여부 점검	
'ifconfig ' 명령을 통하여 sniffing이 수행되고 있는지의 여부를 점검	
'last' 명령을 이용하여 최근의 접속 내역에 대한 점검	
'lastcomm' 명령을 이용하여 비정상적인 명령어의 수행여부를 점검	
/etc/passwd 파일을 조사하여 비 인가된 사용자가 존재하는지를 점검	
/etc/inetd.conf 파일을 조사하여 비 인가된 서비스가 존재하는지를 점검	
/.rhosts, /.forward, /.netrc, /etc/hosts.equiv 파일의 비 인가된 수정 여부	
/etc/rc* 파일들을 조사하여 정상적으로 설정되어 있는지를 점검	
NFS 상태를 조사하여 정상적으로 설정되어 있는지를 점검	
cron, at 관련 파일을 조사하여 정상적으로 설정되어 있는지를 점검	
/.history 또는 /.sh_history 파일을 검사	
'syslog' 파일의 분석을 통하여 인가되지 않은 mail 전송 또는 접속이 이루어졌는지 여부	
'messages' 파일의 분석을 통하여 반복적인 'su'의 실패 또는 'root'로의 접속실패 여부	
'find / -mtime -2 -ls', 'find / -ctime -2 -ls', 'find /dev -type f -ls' 명령을 통하여 비정상적인 파일이 존재하는지를 점검	
'find / -name '.*' -print -xdev | cat -v' 또는 'find / -name '.. ' -print -xdev' 명령을 통하여 의심스러운 파일이 존재하는지를 점검	
'find / -perm -4000 -user root -print' 또는 'find / -perm -2000 -group root -print' 명령을 통하여 backdoor로 의심되는 파일이 존재하는지를 점검	
Cmp, diff 명령을 이용한 의심스러운 파일을 원본 파일과 비교	
strings를 이용하여 의심스러운 파일을 조사	